WEB APPLICATION SECURITY ASSESSMENT

Vulnerability Assessment Report

Target: scanme.nmap.org

Assessment type: Passive, read-only

Tools: Nmap | OWASP ZAP | Browser DevTools

Future Interns - Cyber Security Internship, Task 1

By: Midhat Zaidi

10 October 2026

Executive Summary

A passive security assessment of scanme.nmap.org, a public server provided by the Nmap project for scan practice, using Nmap, OWASP ZAP (Safe Mode) and browser DevTools.

Result: 9 findings (6 Medium, 2 Low, 1 Informational). The site has no HTTPS, runs older server software and lacks common security headers.

Priority: enable HTTPS, update the server, add the headers.

Scope & Methodology

Scope

- Target: scanme.nmap.org (45.33.32.156), authorized for scan practice by its owners
- Passive, read-only analysis of public pages only
- No logins, exploitation, brute force or denial of service
- A scan of testphp.vulnweb.com returned all 100 checked ports as filtered, so it produced no findings
- Third-party sites contacted by the page (Google, Mozilla) are out of scope

Methodology

01 Nmap
Light scan of the top 100 ports to find open services and versions.

02 OWASP ZAP (Safe Mode)
Passive scan while browsing the site; no active attacks.

03 Browser DevTools
Inspected HTTP response headers for security settings.

Nmap: Network & Service Discovery

```
zaidi@zaidis-Air FUTURE_CS_01 % nmap -Pn -sV --top-ports 100 -oN scanme_scan.txt scanme.nmap.org
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-02 03:48 -0700
Warning: Hostname scanme.nmap.org resolves to 2 IPs. Using 45.33.32.156.
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.32s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 95 closed tcp ports (conn-refused)
PORT     STATE    SERVICE  VERSION
22/tcp   open     ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
25/tcp   filtered smtp
80/tcp   open     http     Apache httpd 2.4.7 ((Ubuntu))
1720/tcp filtered h323q931
5060/tcp filtered sip
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.67 seconds
zaidi@zaidis-Air FUTURE_CS_01 %
```

`nmap -Pn -sV --top-ports 100 scanme.nmap.org`

Port	State	Service / version
22/tcp	**Open**	SSH, OpenSSH 6.6.1p1
80/tcp	**Open**	HTTP, Apache 2.4.7
25/tcp	Filtered	SMTP
1720/tcp	Filtered	H.323
5060/tcp	Filtered	SIP

Observation: two services are reachable from the internet (SSH on 22 and the web server on 80), and both run older versions. Only port 80 serves the website, so there is no encrypted HTTPS port. The other 95 checked ports were closed and three were blocked by a firewall, which is good practice.

Medium

Service Findings & Fixes

1. No HTTPS — Medium

Chrome shows 'Not Secure' and only port 80 is open. Data between visitors and the site is not encrypted.

Fix: install a free certificate (for example Let's Encrypt) and redirect all visitors to https.

2. Older web server (Apache 2.4.7) — Medium

The exact version is visible, and it is an older release. Old software is more likely to have known flaws.

Fix: update Apache to a supported version.

3. SSH open to the internet (OpenSSH 6.6.1) — Medium

A login service open to everyone is a common target, and this is an older release.

Fix: update OpenSSH, limit access to trusted addresses, use key-based login.

4. Unused ports blocked — Informational

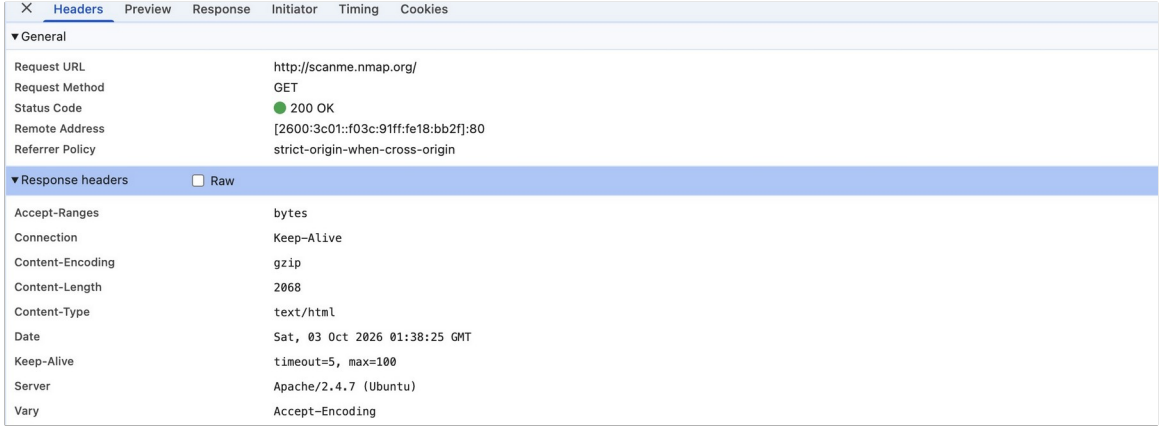
Ports 25, 1720 and 5060 are filtered by a firewall, so those services are not exposed.

Keep: this is good practice.

Browser DevTools: HTTP Headers

scanme.nmap.org in Chrome



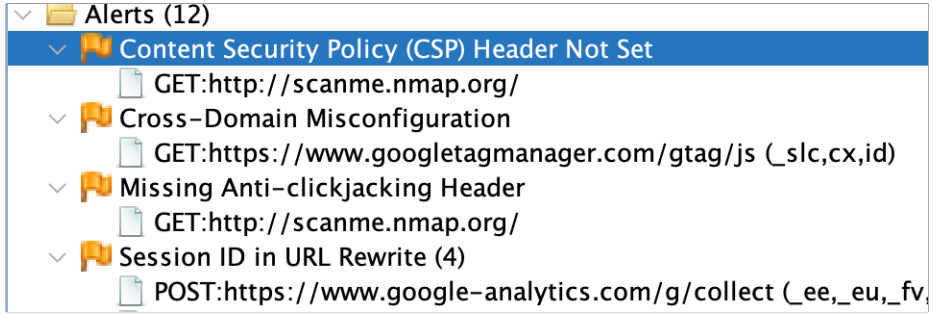


What the headers show

- Server: Apache/2.4.7 (Ubuntu) reveals the exact version
- No Content-Security-Policy
- No X-Frame-Options
- No X-Content-Type-Options
- Page loads over plain http (Not Secure)

OWASP ZAP: Passive Scan Results

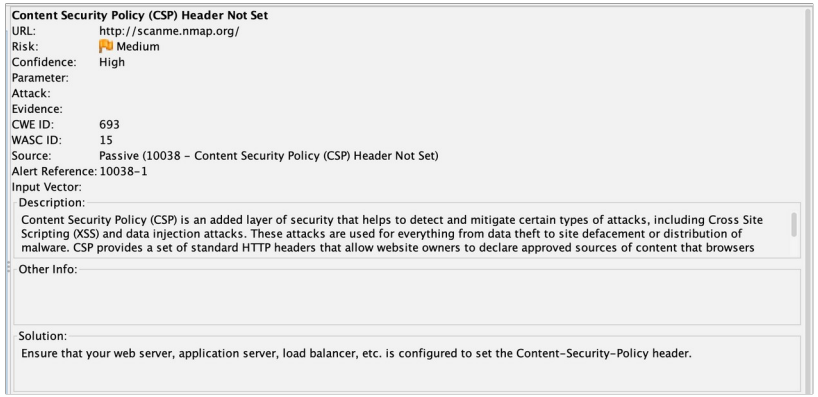
ZAP in Safe Mode: 12 alerts (5 Medium, 4 Low, 3 Informational)



Alert on scanme.nmap.org	**Risk**
Content Security Policy header not set	**Medium**
Missing anti-clickjacking header	**Medium**
Sub Resource Integrity attribute missing	**Medium**
Server leaks version information	**Low**
X-Content-Type-Options header missing	**Low**
Modern web application	**Info**

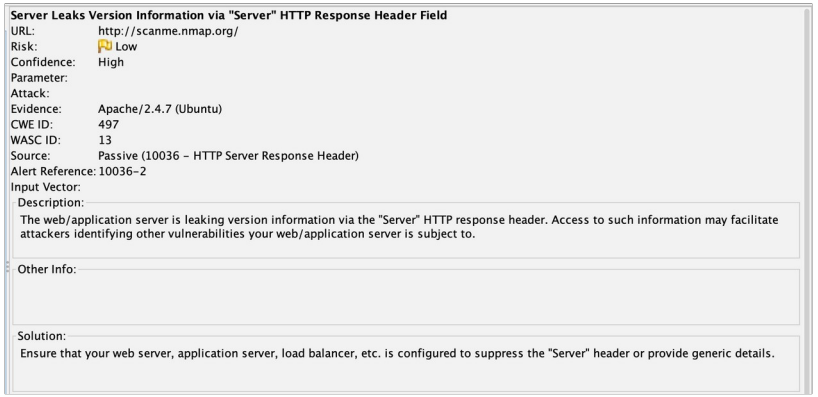
Scope note: the page also loads Google Analytics and Google Tag Manager, and Firefox contacted Mozilla on its own, so ZAP logged alerts for those sites too. They are third-party and out of scope, so only alerts for scanme.nmap.org are counted in this report.

ZAP Alert Details



No Content Security Policy **Medium**

The browser has no rule about which scripts it may trust. Fix: set the Content-Security-Policy header.



Server version leaked **Low**

The Server header shows Apache/2.4.7 (Ubuntu). Fix: hide or generalise the Server header.

Summary of Findings

#	Finding	Risk	Evidence
1	No HTTPS	**Medium**	Chrome, Nmap
2	Older web server (Apache 2.4.7)	**Medium**	Nmap, DevTools
3	Older SSH service (OpenSSH 6.6.1) open to the internet	**Medium**	Nmap
4	No Content Security Policy	**Medium**	ZAP, DevTools
5	No anti-clickjacking protection	**Medium**	ZAP, DevTools
6	Outside scripts not integrity-checked	**Medium**	ZAP
7	Server reveals its exact version	**Low**	ZAP, DevTools
8	Missing X-Content-Type-Options	**Low**	ZAP, DevTools
9	Unused ports blocked by firewall (good practice)	**Informational**	Nmap

What to Fix First

Enable HTTPS

Install a free certificate and redirect all traffic to https.

Update server software

Update Apache and OpenSSH, and limit SSH to trusted addresses.

Add security headers

Add CSP, X-Frame-Options and X-Content-Type-Options, and hide the Server version.

Conclusion

scanme.nmap.org is intentionally open for testing, so these results are expected. They show how a real business website would be reviewed: find the exposed services, check the security settings, rate each risk, and give clear fixes.

The assessment found 9 items: 6 Medium, 2 Low and 1 Informational. None involved exploiting the site; every finding comes from passive observation.

Evidence (screenshots and scan output) is included in the GitHub repository FUTURE_CS_01.